# Module 5.7 Practical Task: Double Extension File Detection

Sigma rule, SIEM view, and task solutions | Iqrar Ali

## 1. Objective

Simulate a scenario where a suspicious file named **invoice.pdf.exe** is created on an endpoint. The goal is to analyze logs, build a Sigma rule, understand how the alert appears in a SIEM, and write a Level 1/2 SOC triage summary.

## 2. Concept: Double Extension Masquerading

A double extension is a technique where an attacker names an executable like a document (for example **invoice.pdf.exe**). Windows often hides known extensions, so the user sees "invoice.pdf" and may open it, running malware. It is commonly delivered through phishing emails or malicious downloads.

| MITRE ID | Technique | Relevance |
|---|---|---|
| T1036.007 | Masquerading: Double File Extension | Main technique detected |
| T1204.002 | User Execution: Malicious File | User runs the disguised file |
| T1036.008 | Masquerading: Masquerade File Type | Related (referenced in the task template) |

Note: the task template links T1036/008, but the technique named Double File Extension is T1036.007.

## 3. Completed Sigma Rule (File Creation)

Maps to Sysmon **Event ID 11** (FileCreate) through the *file_event* category on Windows.

```
title: Double Extension File Created
id: 3f6c1b7e-9a42-4d8e-b5c1-72a0e4d9f318
status: experimental
description: >-
  Detects file creation events with suspicious double file extensions
  that may indicate masquerading.
author: Iqrar Ali
date: 2026/10/20
references:
  - https://attack.mitre.org/techniques/T1036/007/
logsource:
  product: windows
  category: file_event
detection:
  selection:
    TargetFilename|endswith:
      - '.pdf.exe'
      - '.doc.exe'
      - '.docx.exe'
      - '.xls.exe'
      - '.xlsx.exe'
      - '.jpg.exe'
      - '.png.exe'
      - '.txt.exe'
      - '.pdf.scr'
      - '.doc.scr'
      - '.pdf.bat'
      - '.pdf.js'
  condition: selection
falsepositives:
  - Users renaming legitimate files manually
  - Software installers or backup tools with unusual naming
level: medium
tags:
  - attack.defense-evasion
  - attack.t1036.007
  - attack.execution
  - attack.t1204.002
```

## How the rule works

• **logsource:** product *windows*, category *file_event* (Sysmon Event ID 11).

• **TargetFilename|endswith:** matches the end of the file name, so a document extension followed by an executable extension is caught.

• **condition: selection** fires the alert when any listed pattern matches.

• **level: medium** because manual renames can cause false positives; raise to high if execution is also seen.

## 4. Companion Rule: Execution Check (Event ID 4688 / Sysmon 1)

The task asks whether the file was executed. This second rule detects a process started from a double extension file.

```
title: Execution of Double Extension File
id: 8b2d5e4a-1c73-4f09-a6d8-95e3b0c7a124
status: experimental
description: Detects execution of a process whose image name has a double extension.
author: Iqrar Ali
date: 2026/10/20
references:
  - https://attack.mitre.org/techniques/T1036/007/
logsource:
  product: windows
  category: process_creation
detection:
  selection:
    Image|endswith:
      - '.pdf.exe'
      - '.doc.exe'
      - '.docx.exe'
      - '.xls.exe'
      - '.jpg.exe'
  condition: selection
falsepositives:
  - Rare legitimate software with unusual naming
level: high
tags:
  - attack.defense-evasion
  - attack.t1036.007
```

**Event ID 4688** (Windows Security) requires *Audit Process Creation* to be enabled. In Sysmon, the equivalent is Event ID 1. Correlating file creation (rule 1) with execution (rule 2) on the same host and user raises confidence and severity.

## 5. How It Appears in a SIEM

Flow: **Endpoint (Sysmon) -> Agent (Wazuh/Splunk forwarder) -> SIEM -> Rule match -> Alert -> SOC analyst**

| Field | Example value (illustrative) |
|---|---|
| Rule / alert | Double Extension File Created (medium) |
| Event ID | 11 (Sysmon FileCreate) |
| Host | WIN10-PC01 |
| User | DOMAIN\user1 |
| TargetFilename | C:\Users\user1\Downloads\invoice.pdf.exe |
| Image (creator) | C:\Program Files\Browser\browser.exe |
| Time | From the log timestamp |

These values are illustrative. Replace them with the values from the sample logs your instructor provides.

## Example Splunk search

```
index=sysmon EventCode=11
| where like(TargetFilename, "%.pdf.exe") OR like(TargetFilename, "%.doc.exe")
| table _time, host, User, Image, TargetFilename
```

## Example Wazuh / Event ID 4688 check

```
index=wineventlog EventCode=4688 NewProcessName="*invoice.pdf.exe"
| table _time, host, SubjectUserName, NewProcessName, ParentProcessName, CommandLine
```

## 6. Solutions to the Task Questions

## A. Check list (answer from the provided logs)

| Question | Where to find it | Your answer |
|---|---|---|
| Which user created the file? | Sysmon 11: User field | _____ |
| What time? | Event UtcTime / _time | _____ |
| Which directory? | TargetFilename path | _____ |
| Was it executed? | Event ID 4688 / Sysmon 1: invoice.pdf.exe or cmd.exe | _____ |

## B. Is this behavior suspicious? Why?

• **Yes.** Legitimate PDFs never end in .exe; the extension chain is designed to deceive the user.

• It matches known masquerading (T1036.007) used in phishing and malware delivery.

• Risky locations (Downloads, Temp, Desktop, AppData) and an unknown creator process increase suspicion.

• If the file was executed, it may mean initial access, malware installation, or C2 communication.

## C. What would an L1 analyst do next?

• **1. Validate the alert:** confirm user, host, time, full path, and the creating process.

• **2. Check execution:** look for Event ID 4688 / Sysmon 1 for invoice.pdf.exe and its parent process (Outlook, browser, cmd.exe).

• **3. Hash reputation:** get the SHA256 and check VirusTotal or threat intel.

• **4. Contact the user:** ask whether they expected the file and where it came from.

• **5. Decide:** if executed or the hash is malicious, escalate to L2 and request host isolation; if benign, document and close as a false positive.

## D. How would an L2 analyst investigate deeper?

• **DNS and network logs:** look for connections to unusual domains/IPs after execution (possible C2 beaconing).

• **Process tree:** check child processes such as PowerShell, cmd, rundll32, or wscript.

• **Persistence:** check Run registry keys, scheduled tasks, new services, and startup folders.

• **User behavior:** review the email source, other downloads, and unusual logins.

• **File hash reputation:** VirusTotal, sandbox detonation, and static analysis.

• **Threat hunting:** search other hosts for the same hash, filename, or domain.

• **Containment and recovery:** isolate the endpoint, reset credentials, block IOCs, and remove artifacts.

## 7. SOC Triage Summary (Template)

| Item | Details |
|---|---|
| Alert | Double Extension File Created |
| Severity | Medium (High if executed) |
| Host / User | _____ / _____ |
| File path | _____\invoice.pdf.exe |
| Time (UTC) | _____ |
| Executed? | Yes / No (Event ID 4688 / Sysmon 1) |
| Hash reputation | _____ |
| Assessment | Suspicious masquerading attempt. True positive if the hash is malicious or the user did not expect the file. |
| Action taken | Escalated to L2 / host isolated / user notified / closed as FP |
| MITRE | T1036.007, T1204.002 |